6 Best practices

This chapter covers

- Opening up your API to public CORS requests
- Limiting CORS requests to a whitelisted set of origins
- Ensuring your CORS responses are properly handled by proxy servers
- Protecting against cross-site request forgery (CSRF) vulnerabilities
- Configuring and minimizing preflight requests

The previous chapters showed how Access-Control prefixed HTTP headers can dictate the behavior of CORS requests. There are six CORS-specific response headers, each with its own set of valid values. This can lead to myriad ways in which the server response can be configured. While the previous chapters explained what these HTTP headers do, they didn't offer a lot of guidance on how to best use these headers. How should you configure your server if you want to whitelist certain clients? How can your server accept cookies while still remaining secure?

This chapter will answer these questions and show you how to configure these headers in a way that makes sense for your server needs. If HTTP headers are the language of CORS, this chapter aims to improve your CORS grammar.